IT Security, Access & Data Handling Standard

Identity, devices, customer data, and incident response

Document ID	03_IT_SECURITY_AND_DATA_HANDLING
Version	4.1
Effective date	01 November 2026
Document owner	IT & Security
Classification	Internal – Fictional training content

Purpose

This controlled document contains invented company-specific facts, rules, limits, names, and procedures. It is designed to be ingested into a Retrieval-Augmented Generation (RAG) system so that answers can be grounded in source documents rather than model assumptions.

1. Identity and authentication

• Every employee must use an individually assigned Asterion identity. Shared employee accounts are prohibited.

• Multi-factor authentication (MFA) is mandatory for email, source control, cloud consoles, PeopleHub, and FinanceDesk.

• Passphrases must be at least 14 characters. Password reuse across Asterion and personal services is prohibited.

• Hardware security keys are required for production administrators and members of the Security team. Authenticator-app MFA is acceptable for other employees.

• Access requests must identify the system, business purpose, requested role, manager, and required end date. Default access is read-only where practical.

2. Joiner, mover, leaver controls

• Managers submit joiner access requests at least 3 business days before the start date.

• Role changes require a new access review; existing permissions do not automatically remain appropriate.

• On a confirmed separation, IT disables interactive access no later than the employee's recorded last working day. For involuntary or security-related separations, access may be disabled earlier at the direction of People Operations or Legal.

• Managers must review team access quarterly. Production access is reviewed monthly.

3. Device standard

• Company-managed laptops must use full-disk encryption, endpoint detection, automatic screen lock within 5 minutes, and supported operating-system versions.

• Employees may not disable endpoint protection, encryption, or mobile-device management.

• Personal devices may access webmail only through the managed browser profile. Downloading customer data to a personal device is prohibited.

• USB storage is blocked by default. A time-limited exception requires approval from IT Security and the data owner.

• Lost or stolen devices must be reported to security@asterion-works.example within 30 minutes of discovery, even if the device is believed to be encrypted.

4. Data classification

Public: Approved for unrestricted public distribution.

Internal: Routine company information. Share only with employees and approved contractors who need it.

Confidential: Business-sensitive information such as contracts, employee records, unreleased financials, and non-public product plans. Share only with named, authorised recipients.

Restricted: Customer personal data, authentication secrets, payment tokens, production credentials, and security incident evidence. Access requires explicit business need and approved systems.

• Classification is determined by the most sensitive content in a file or dataset. Combining Internal and Restricted data makes the combined output Restricted.

5. Customer data rules

• Customer production data must remain in the approved customer tenant and approved regional storage location.

• Production data may not be copied into development, test, training, or demonstration environments.

• Anonymised datasets may be used for testing only after the data owner confirms that direct identifiers and re-identification keys have been removed.

• Support staff must use the customer-approved support workflow. Exporting a customer dataset to a local spreadsheet for convenience is prohibited.

• Customer data exports require a ticket, named requester, purpose, data scope, and expiry date. The default download link expiry is 24 hours.

6. Software and AI tools

• Only software listed in the Approved Software Catalogue may be installed on managed devices.

• Employees must not paste Confidential or Restricted information into public AI assistants, public code-generation websites, or unapproved transcription services.

• Internal AI tools may process Internal data. Confidential data requires approval from the data owner; Restricted data is prohibited unless a specific system has written Security and Legal approval.

• AI-generated code must undergo the same review, testing, licensing, and security checks as human-written code. The author remains accountable for submitted code.

• Browser extensions that read page contents require IT Security approval.

7. Security incident response

• Report suspected phishing, credential exposure, malware, accidental disclosure, or lost devices to security@asterion-works.example immediately.

• Do not delete suspicious messages, logs, or files before Security has advised. Preserve evidence and note the time discovered.

• Security acknowledges a critical incident within 15 minutes, a high incident within 1 hour, and a normal incident within 1 business day.

• Employees must not notify customers, regulators, or the press about a suspected incident unless authorised by Legal or the incident commander.

• Incident severity is assigned by Security, not by the person reporting it.

8. Retention and disposal

• Employees must store business records in approved systems, not personal drives or messaging apps.

• Local temporary copies of customer files must be deleted within 24 hours after the approved task is complete.

• Security logs are retained for 400 days unless a legal hold or incident investigation requires longer retention.

• Employees must not destroy, alter, or conceal records subject to a legal hold.

9. Exceptions and enforcement

• Exceptions must specify scope, owner, compensating controls, and expiry date. Security exceptions expire after 90 days unless renewed.

• Only the Head of IT Security may approve an exception to this standard. System owners may recommend but cannot independently approve one.

• Suspected violations are reviewed with People Operations and Legal. This standard does not replace applicable law or contractual obligations.

End of document — Questions should be routed to the document owner listed above. If the answer is not stated here or in another applicable controlled document, say that the knowledge base does not specify it.